

SWE308: Information Security

Lecture 10: Asymmetric Crypto and Public Key Infrastructure

Do you trust a public key?

How do you ensure that the public key that you have is the authorised receiver's public key?

Dr Iftekhar Salam
iftekhar.salam@xmu.edu.my

Xiamen Univesity Malaysia

Presentation Outline

- 1 Digital Signature
- 2 Distribution of Public Keys
- 3 Public Key Trust Models
- 4 Digital Certificates and Trust
- 5 Public Key Infrastructure (PKI)

Presentation Outline

- 1 Digital Signature
- 2 Distribution of Public Keys
- 3 Public Key Trust Models
- 4 Digital Certificates and Trust
- 5 Public Key Infrastructure (PKI)

Can We Use Asymmetric Cryptography for User Authentication?

Using asymmetric cryptography, each entity has a unique key pair:

- One key is kept private (known only to owner of key)
- The other key is public (anyone can know this)

So, in last week lecture we have seen that asymmetric cryptography can be used to provide confidentiality

Can we use asymmetric cryptography to provide user authentication and message authentication?

- YES!
- Use asymmetric cryptography to generate a **digital signature**

Asymmetric Cryptography for User Authentication

We can generate **digital signature** using asymmetric cryptography to provide the security service: **user authentication**

One key is used for generating signature and one key is used for verification of signature. Which key do you think we should use for signature generation? Which key do you think we should use for signature verification?

Asymmetric Cryptography for User Authentication

We can generate **digital signature** using asymmetric cryptography to provide the security service: **user authentication**

One key is used for generating signature and one key is used for verification of signature. Which key do you think we should use for signature generation? Which key do you think we should use for signature verification?

- A private key can be used by the owner to form a digital signature for a particular message or file
- The corresponding public key can be used by others to verify the digital signature on the message
 - Provides authentication of the sender for a particular message
 - Since only the signer knows the private key, only the signer could have created the digital signature

User Authentication - Digital Signatures

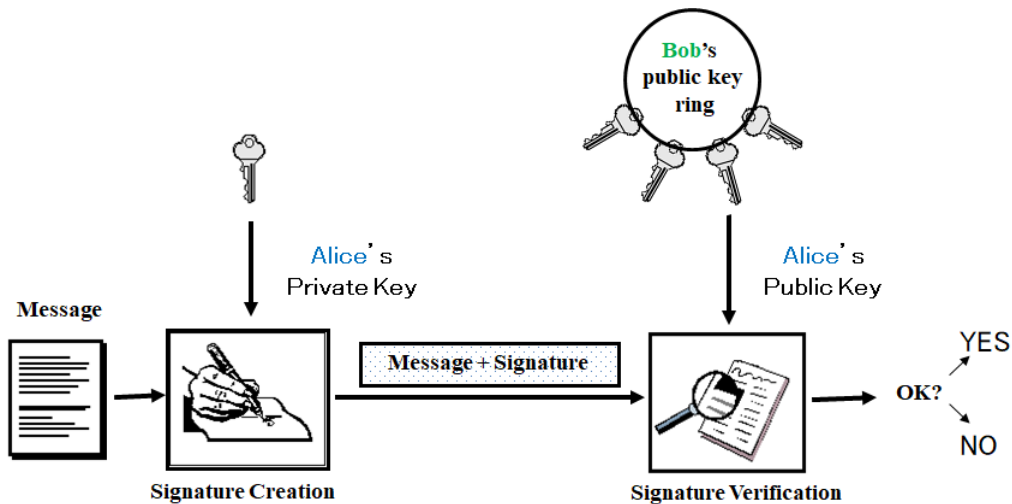


Figure: Basic Operation: Alice signs a message

User Authentication - Digital Signatures

Similarities to handwritten signatures:

- unique to signer
- verifiable
- legally binding

Important differences:

- digital signature is different for every document
 - WHY?
- digital signature must be produced and verified by a machine

A digital signature is completely different from a digitized signature

User Authentication - Common Examples of Digital Signatures

The most widely used digital signature schemes are:

- **RSA**
 - exploits symmetry in RSA encryption/decryption algorithms
 - Relies on the difficulty of factoring large numbers
- **DSA (Digital Signature Algorithm):**
 - Also referred to as DSS (Digital Signature Standard)
 - Relies on the difficulty of solving the discrete log problem
- **ECDSA (Elliptic Curve DSA):**

DSA, RSA, and ECDSA are currently the only FIPS-approved methods for digital signatures

Programming
Techniques

S.L. Graham, R.L. Rivest*
Editors

A Method for Obtaining Digital Signatures and Public-Key Cryptosystems

R. L. Rivest, A. Shamir, and L. Adleman
MIT Laboratory for Computer Science
and Department of Mathematics

An encryption method is presented with the novel property that publicly revealing an encryption key does not thereby reveal the corresponding decryption key. This has two important consequences:

(1) Couriers or other secure means are not needed to transmit keys, since a message can be enciphered using an encryption key publicly revealed by the intended recipient. Only he can decipher the message, since only he knows the corresponding decryption key.
(2) A message can be "signed" using a privately held decryption key. Anyone can verify this signature using the corresponding publicly revealed encryption key. Signatures cannot be forged, and a signer cannot later deny the validity of his signature. This has obvious applications in "electronic mail" and "electronic funds transfer" systems. A message is encrypted by representing it as a number M , raising M to a publicly specified power e , and then taking the remainder when the result is divided by the publicly specified product, n , of two large secret prime numbers p and q . Decryption is similar; only a different, secret, power d is used, where $e \cdot d = 1 \pmod{(p-1) \cdot (q-1)}$. The security of the system rests in part on the difficulty of factoring the published divisor, n .

Key Words and Phrases: digital signatures, public-key cryptosystems, privacy, authentication, security, factorization, prime number, electronic mail, message-passing, electronic funds transfer, cryptography.

CR Categories: 2.12, 3.15, 3.50, 3.81, 5.25

Digital signatures and Hash Functions

For efficiency, signature schemes typically use a hash function to reduce amount of material processed using asymmetric cryptography

- To create a signature for message, m
 - first compute the hash of m , and
 - then proceed with the other steps of the signing method
 - What is the advantage of hashing before the signature generation?
- Any change in message m should result in a different hash value, so digital signatures provide some assurance of message integrity
 - Important to use the same hash function during both:
 - the signature creation process, and
 - the signature verification processes

Digital Signatures: RSA Signatures

Key generation same as RSA encryption:

- The public signing key is (n, e) - should be available to anyone
- The private signing key is d - must be kept confidential

Signature generation of message m :

- Calculate hash: $h = H(m)$ with $0 < h < n$
- Calculate: $s = h^d \bmod n$

Verification of claimed signature s on message m

- Calculate hash: $h = H(m)$ with $0 < h < n$
- Calculate: $h' = s^e \bmod n$
- If $h' = h$ then accept signature, otherwise reject it

Digital Signatures and Security Services

Digital signatures provide:

- Authentication of message sender
- Some assurance of message integrity

They can also provide non-repudiation:

- A third party (judge) can decide if a specific party signed a message
 - For a digital signature scheme to provide non-repudiation, the hash function used in signing must be collision-resistant
 - This cannot be achieved with symmetric key authentication, such as with a MAC
 - Why?
 - This makes digital signatures particularly useful for electronic commerce applications

Presentation Outline

- 1 Digital Signature
- 2 Distribution of Public Keys
- 3 Public Key Trust Models
- 4 Digital Certificates and Trust
- 5 Public Key Infrastructure (PKI)

Trust issues?

Do you trust the public key that you have? How do you know that this is Alice's public key and what assurance do you have that Eve has not replaced Alice's public key with her (Eve) own public key?

Public Keys and Trust

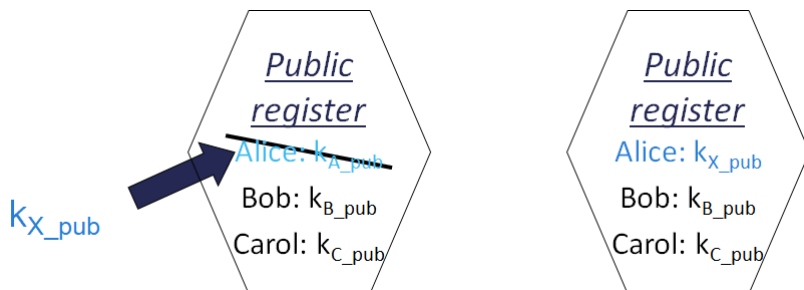
How can a user be sure who a public key belongs to?

- Can a user be sure a public key has not been **altered** - intentionally or unintentionally?
- What are the security implications if this happens?

Major issues associated with the use of asymmetric cryptography (particularly the public keys) are:

- The integrity of public keys:
 - Do you have the correct value for the key? (remember some of these keys can be very long – say, 2048 bits or 4096 bits)
- The trustworthiness of public keys:
 - Is this actually the key that belongs to the entity you think it does?

Public Keys and Trust: The Spoofing Problem



Suppose an attacker, X, changes the value of Alice's public key in a register (so it says Alice's public key, but the actual value is one that the attacker chose, and knows the corresponding private key value)

How does this affect the security of:

- Does it affect a confidential message sent to A? **Why?**
- Does it affect a digital signature on a message received from A? **Why?**

Public Keys and Trust

Q: How can public keys be made available in a trusted way?

A: Find someone to vouch for the public key information that is provided:

- **People who know the entity** and are prepared to endorse the key, or
- **A trusted authority** who performs checks and can endorse the key as belonging to the entity
 - Endorsement in digital certificates issued by a **Certification Authority (CA)**.

Different trust models based on these two different approaches

Presentation Outline

- 1 Digital Signature
- 2 Distribution of Public Keys
- 3 Public Key Trust Models
- 4 Digital Certificates and Trust
- 5 Public Key Infrastructure (PKI)

Public Key Trust Models

Public key trust models can be:

- **User Centric:**

- Each user has a key ring containing public keys of other users they trust
- Users are **completely responsible** for deciding which public keys to trust
- Examples: PGP (Pretty Good Privacy), Open PGP, GPG

- **Trusted Authority Models:**

- Have trusted authorities perform checks and issue certificates endorsing the public keys of entities
- Relationships between the Certificate Authorities vary
- Examples include: Strictly hierarchical model

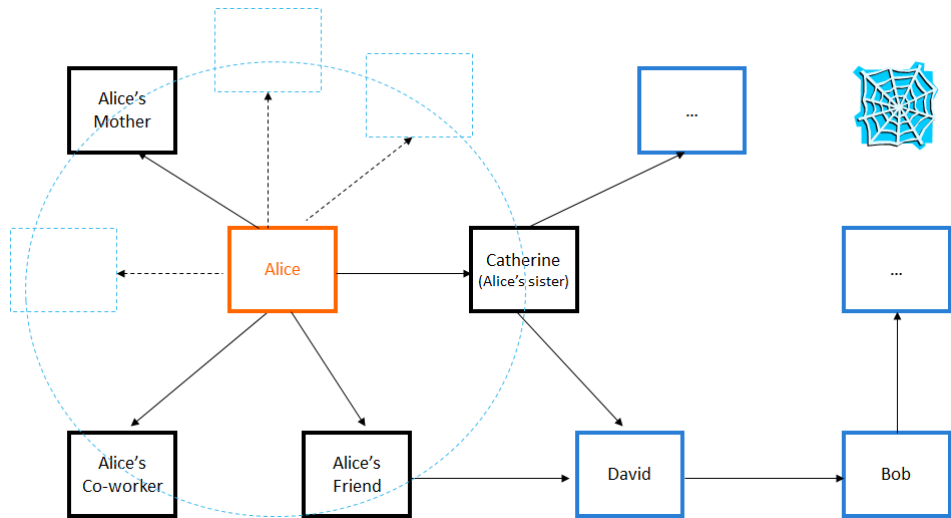
- **Browser Model**

User Centric Trust Model

Public keys can be distributed by key servers and verified by fingerprints

- Each user:
 - has a key ring containing public keys of other users they trust
 - may sign public keys that they will trust
- Example: Pretty Good Privacy (PGP) 'Web of Trust'
- OpenPGP Public Key Server <http://pgpkeys.mit.edu/>

User Centric Trust Model



User Centric Trust Model

Advantages:

- Simple and free
- Works well for a small number of users
- Does not require expensive infrastructure to operate
- User-driven operation

Disadvantages:

- Relies on human judgment
 - Might work well with technical users aware of the issues, but not general public
- Not appropriate for trust-sensitive areas
 - such as finance and government

Presentation Outline

- 1 Digital Signature
- 2 Distribution of Public Keys
- 3 Public Key Trust Models
- 4 Digital Certificates and Trust
- 5 Public Key Infrastructure (PKI)

Trusted Authority Models (Certificate Authority)

Alternative approach:

- have an authority that checks details of entity claiming ownership of a particular public key, and provides a (verifiable) certificate – a **digital certificate**

A **Certificate Authority (CA)** creates and digitally signs the certificate

- The CA is vouching for the information in the certificate
- **Purpose of CA signature?**

A **digital certificate** contains:

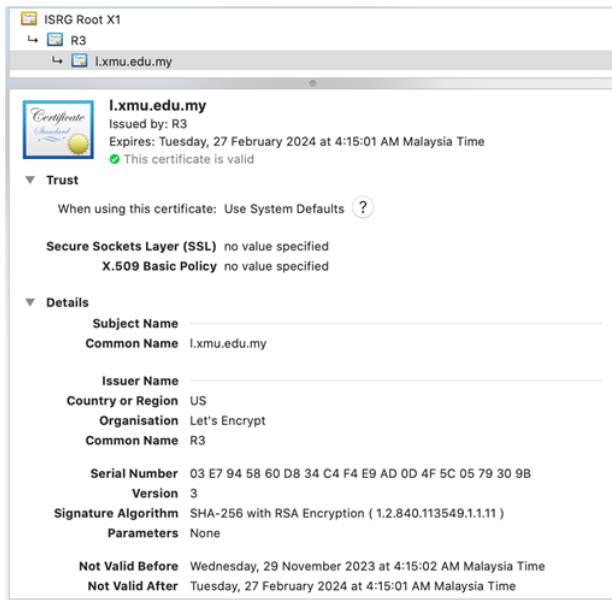
- the user's public key,
- the user's ID
- plus some other information: e.g., validity period

Trusted Authority Models (Certificate Authority)

Digital certificates and trust:

- Most widely used format for dig certs: X.509 standard
- Recommended by International Telecommunication Union (ITU-T)
- Important fields in X.509 digital certificates are:
 - Version number
 - Serial Number (set by the CA)
 - Signature Algorithm identifier (Algorithm used for dig sigs)
 - Issuer (Name of the CA)
 - Subject (Name of entity to which certificate has been issued)
 - Public Key Information
 - Validity period (certificate should not be used outside this time)
 - Digital signature (of the certificate, signed by the CA)

Digital Certificate - Moodle Example



Creating A Digital Certificate

How does Alice obtain a digital certificate for her public key?

- ① Alice generates a key pair
- ② Alice **keeps the private key secret** and sends to the CA:
 - her identity details, ID_A
 - her public key, K_{A-pub}
 - any other information required by the CA
- ③ The CA then:
 - performs any required checks to verify Alice's identity,
 - creates a certificate containing ID_A and K_{A-pub}
 - sends the certificate, $Cert_A$, to Alice

Can you trust this?

Creating A Digital Certificate

How does Alice obtain a digital certificate for her public key?

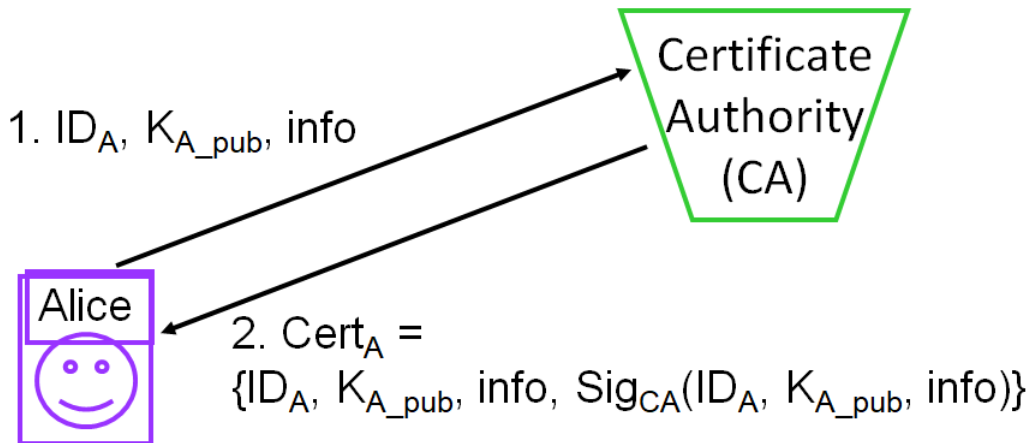
- ① Alice generates a key pair
- ② Alice **keeps the private key secret** and sends to the CA:
 - her identity details, ID_A
 - her public key, K_{A-pub}
 - any other information required by the CA
- ③ The CA then:
 - performs any required checks to verify Alice's identity,
 - creates a certificate containing ID_A and K_{A-pub}
 - sends the certificate, $Cert_A$, to Alice

Can you trust this?

- To trust a certificate, you need to trust that the CA that issued the certificate has performed the necessary checks

Digital Certificates and Trust

How does Alice obtain a digital certificate for her public key?



Using A Digital Certificate

How do I use Alice's digital certificate?

- For **Confidentiality**: Suppose Bob wants to send a confidential message to Alice:

$$C = E(M, K_{A_pub})$$

- 1 Bob needs Alice's public key for the encryption:

- Bob obtains $Cert_A$
- Bob verifies $Cert_A$
- Bob obtains K_{A_pub} from $Cert_A$

- If Bob:

- trusts the CA that issued $Cert_A$ and
- is certain of the CA's public key

then Bob can be sure that only Alice will be able to decrypt the ciphertext message he sends to Alice

Trusting A Digital Certificate

Q: Can I trust Alice's digital certificate - $Cert_A$?

A: Do I trust the CA who issued it - and is that really the CA's public key?

To verify the CA's signature on $Cert_A$, I need to use the CA's public key

- If I don't know this already, I can obtain it from the CA's certificate
- To verify that certificate, I need to use what?

Trusting A Digital Certificate

Q: Can I trust Alice's digital certificate - $Cert_A$?

A: Do I trust the CA who issued it - and is that really the CA's public key?

To verify the CA's signature on $Cert_A$, I need to use the CA's public key

- If I don't know this already, I can obtain it from the CA's certificate
- To verify that certificate, I need to use what?
 - the public key of the CA who issued that certificate ...

Some infrastructure is required to enable implementation of public key cryptography

Presentation Outline

- 1 Digital Signature
- 2 Distribution of Public Keys
- 3 Public Key Trust Models
- 4 Digital Certificates and Trust
- 5 Public Key Infrastructure (PKI)

Public key infrastructure

Public key crypto needs a **Public Key Infrastructure (PKI)** to provide security services

A PKI is a set of:

- Policies (to define the rules for managing certificates)
- Products (hardware and/or software) (to implement the policies and generate, store and manage certificates)
- Procedures (related to key management)

that enable users to implement public key cryptography - often in large, distributed settings

Trusting A Digital Certificate

Critical component of system is the Certification Authority (CA)

- The CA **creates and issues digital certificates** to other parties
- The **level of trust** you can place in a certificate depends on the amount of checking a CA does to establish the credentials of requester before providing a certificate

Who is the CA?

- Some large organisations have their own CA
- Commercial CA's charge to provide certificates, and may offer various grades
 - More thorough checking generally means greater cost

Certification Authority (CA) – Examples

Malaysia – List of certification authorities

- <https://www.mcmc.gov.my/en/sectors/digital-signature/list-of-licensees>
- <https://www.posdigicert.com.my>
- <https://www.tmca.com.my>
- <https://www.msctrustgate.com>

Trusting A Digital Certificate

Q: Are all digital certificates trustworthy?

A: No!

- Many known cases of spoofed digital certificates:
 - July 2014: India's NIC issued fraudulent Cert for Google
 - Dec 2012: CA linked to TURKTRUST issued fraudulent Cert for Google
 - July 2011: DigiNotar - over 500 fraudulent certificates issued, including cert's for Google, Yahoo!, Mozilla, Wordpress
 - March 2011: Nine fraudulent certificates issued by Comodo, supposedly to various Google, Yahoo! and Skype servers
- Reaction: certificates can be revoked (canceled before expiry date)
 - Certificate Revocation Lists (CRL), or
 - Online Certificate Status Protocol (OCSP) before trusting certificate
- Also possible to create a self-signed certificate:
 - The certificate creator is also verifying the contents
 - Be careful about trusting these! Would you trust credentials in a home-made driver's licence?

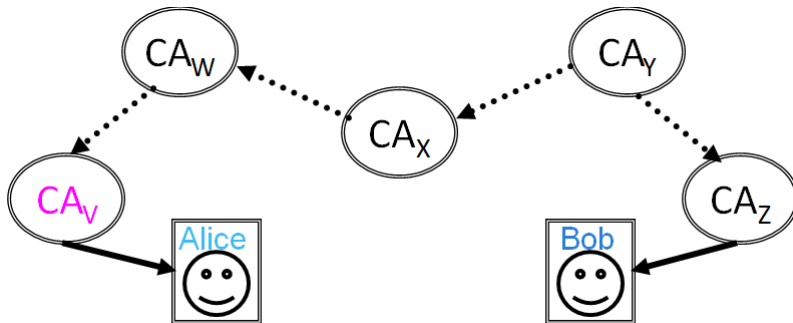
Trust Pathways

In large deployments all users may not have the same CA

- To create a **chain of trust** between users, CAs must have their public keys certified by other CAs
- The user may need to verify multiple certificates in order to establish a trust pathway

All users need to trust one or more CAs in order to start constructing a trust pathway

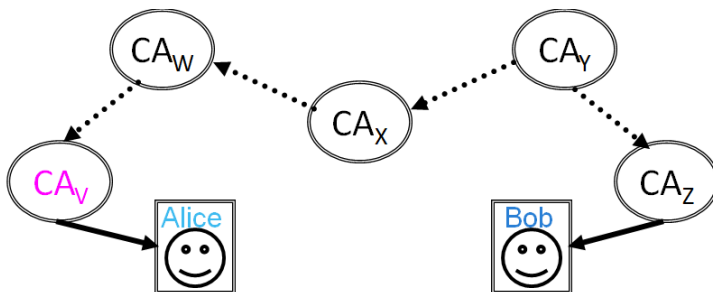
For Bob to be assured the integrity of Alice's public key, need to create a path of trust from Alice to Bob, using connections between the CAs



PKI: Certification Paths

Bob wants to use Alice's public key

- Bob has Alice's digital certificate $Cert_A$ containing Alice's public key issued by CA_V
 - CA_V may need to provide certificate for it's public key
 - CA_V may obtain $Cert_V$ from CA_W
 - CA_W may obtain $Cert_W$ from CA_X
 - CA_X may obtain $Cert_X$ from CA_Y
- Bob's own digital certificate is from CA_Z
 - CA_Z 's $Cert_Z$ is issued by CA_Y
- A certification path is established



PKI: Certification Paths - Moodle Example

The image displays three overlapping screenshots of a Moodle PKI certification path viewer, illustrating the hierarchy from the root certificate to the end entity.

ISRG Root X1 (Root Certificate Authority):

- Trust:** When using this certificate: Use System Defaults. Secure Sockets Layer (SSL) no value specified. X.509 Basic Policy no value specified.
- Details:**
 - Subject Name: Country or Region US, Organisation Internet Security Research Group, Common Name ISRG Root X1.
 - Issuer Name: Country or Region US, Organisation Internet Security Research Group, Common Name ISRG Root X1.
 - Serial Number: 00 82 10 CF B0 D2 40 E3 59 44 63 E0 BB 63 82 8B 00.
 - Version: 3.
 - Signature Algorithm: SHA-256 with RSA Encryption (1.2.840.113549.1.1.1).
 - Parameters: None.

R3 (Intermediate Certificate Authority):

- Trust:** When using this certificate: Use System Defaults. Secure Sockets Layer (SSL) no value specified. X.509 Basic Policy no value specified.
- Details:**
 - Subject Name: Country or Region US, Organisation Let's Encrypt, Common Name R3.
 - Issuer Name: Country or Region US, Organisation Internet Security Research Group, Common Name ISRG Root X1.
 - Serial Number: 00 91 2B 08 4A CF 0C 18 A7 53 F6 D6 2E 25 A7 E.
 - Version: 3.
 - Signature Algorithm: SHA-256 with RSA Encryption (1.2.840.113549.1.1.1).
 - Parameters: None.

lxmdu.edu.my (End Entity):

- Trust:** When using this certificate: Use System Defaults. Secure Sockets Layer (SSL) no value specified. X.509 Basic Policy no value specified.
- Details:**
 - Subject Name: Common Name lxmdu.edu.my.
 - Issuer Name: Country or Region US, Organisation Let's Encrypt, Common Name R3.
 - Serial Number: 03 E7 94 58 60 D8 34 C4 F4 E9 AD 0D 4F 6C 05 79 30 9B.
 - Version: 3.
 - Signature Algorithm: SHA-256 with RSA Encryption (1.2.840.113549.1.1.1).
 - Parameters: None.
 - Not Valid Before: Wednesday, 29 November 2023 at 4:15:02 AM Malaysia Time.
 - Not Valid After: Tuesday, 27 February 2024 at 4:15:01 AM Malaysia Time.

PKI: trust models

- Trust relationships

- between different Certificate Authorities, and
- between Certificate Authorities and end users,

define PKI trust models

- Common PKI Trust models are:

- Hierarchical
 - Strict hierarchical
 - Distributed trust architectures
- Browser

PKI: trust models

Strict Hierarchical Model

- Tree structure:
 - Single root CA
 - Users are leaves of the tree
 - Each node is certified by its immediate parent CA
- Highly regulated:
 - Each CA must follow rules regarding to whom they may issue certificates
- Root CA:
 - Starting point for trust
 - All users trust the root CA, and must receive its public key through a secure out-of-band channel

PKI: trust models

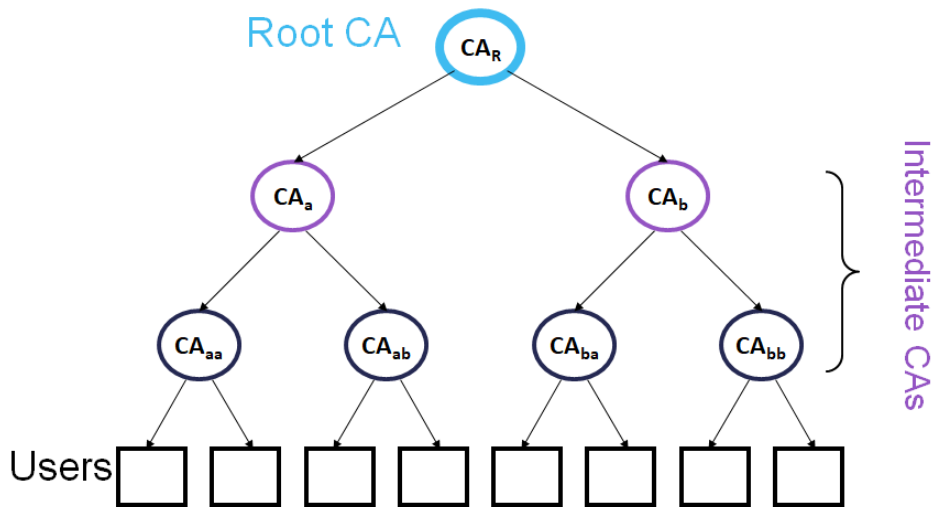


Figure: Strict hierarchical model

PKI: trust models

Strict Hierarchical Model

- **Advantages:**

- works well in highly-structured setting such as military and government
- unique certification path between two entities (so finding certification paths is simple)
- scales well to larger systems

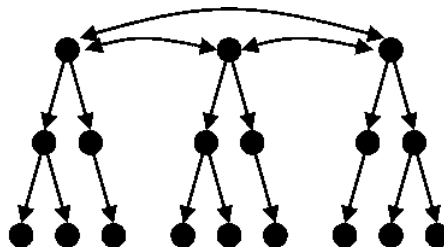
- **Disadvantages:**

- need a trusted third party (root CA)
- 'single point-of-failure' target
- If any node is compromised, trust impact on all entities stemming from that node
- Does not work well for global implementation (**who is root TTP?**)

PKI: trust models

Distributed trust hierarchical architectures:

- Interconnection of multiple hierarchies
- No single root CA, multiple cross-certified root CAs
- Trust is distributed among the root CAs



Cross certified strict hierarchies

Figure: Distributed trust hierarchical architecture

PKI: trust models

Browser model

- Used by most well known browsers including *Mozilla Firefox* and *Microsoft Internet Explorer*
- Some CA certificates pre-installed in the browser
 - Installed certificates are used as trusted 'root' CA certificates for verifying incoming certificates
- The browser user trusts the browser vendor who installed the certificates, rather than a root CA
- May also include list of 'untrusted' certificates
 - Check your browser certs for some of the known fraudulent certs:
 - Comodo and DigiNotar certs revoked in 2011, etc

PKI: trust models

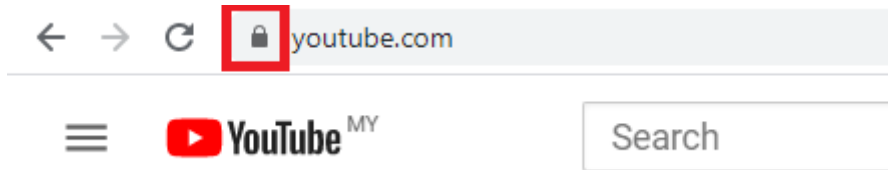
Browser model limitations:

- Certification path processing is limited
 - Incoming certificates can only be verified by available 'trusted' certs
- List of trusted certificates controlled by user - not well protected from modification attacks
 - If prompted, many users automatically accept incoming certificates that cannot be verified by 'trusted certificates'

PKI: trust models

Browser model:

- What are the security implications of user control over certificate acceptance?
 - Consider the case where certificates are used to authenticate internet bank site.
 - Many users look for a visual symbol (padlock) for assurance that their transactions will be secure.
 - When you see this symbol, what is actually being secured?



PKI: trust models

Browser model - security implications of user control over certificate acceptance?

Website authentication scenario:

- You get a phishing email that pretends it is from your bank
 - Contains a link to a fake website that looks much the same as the legitimate bank site
 - You click on the link
- A man-in-the-middle approach and a fraudulent certificate (self-signed or a low-grade certificate issued by a CA without any serious credential checking) can be used to produce convincing websites:
 - If the user accepts certificate without checking details or certificate pathway,
 - then the public key details from the certificate are used to secure communications between the fake site and user (padlock symbol)
- So the communication is secure, but you are communicating securely with the attacker – not the entity you thought you were connecting with!

Summary of Symmetric vs Asymmetric Crypto

- Key management essential for implementing secure crypto
- Symmetric key crypto:
 - Can be used to provide confidentiality and integrity assurance
 - Can we use symmetric crypto to provide user authentication or non-repudiation?
 - Faster in comparison to asymmetric ciphers
 - But secure key establishment & distribution is difficult without a TTP
- Asymmetric crypto:
 - Can be used to provide confidentiality, integrity assurance, user authentication, non-repudiation
 - Computationally expensive and slower in comparison to symmetric ciphers
 - Key distribution simpler – public key does not require confidentiality
 - However, can be spoofed
- How can you trust the public key?
 - Trust models:
 - User centric – user decides who to trust
 - Trusted Authority - Digital certificates used to manage trust for public keys
 - Browser - Digital certificates but under user control
 - All models have limitations
 - Consider where user actions may compromise security

End of Lecture 10! 😊

Remember to complete your quiz!

- Do review back the questions that you answered incorrectly (if any) in the quiz
- Do let me know if you find any inconsistencies in the quiz marking
- Feel free to consult if you have queries about anything (quiz, lecture, tutorial, assignment,) in regards to this course

Reminder on assignment

- Be careful of AI generated materials (including translation software) – will be heavily penalized

Next Week Lecture

- Network security
- And a little on modular exponentiation

QUESTIONS?

Appendix: University's vision and mission

- ① Vision: Xiamen University Malaysia aspires to become a university with a distinct global outlook, featuring first-class teaching and research, and embracing cultural diversity.
- ② Mission: To nurture young talents with dignity and wisdom, turning them into fine citizens of the region who will contribute to the prosperity of the people and social progress of Malaysia, China and Southeast Asia.